Panel prep: MRM in the Era of GenAI

Oct 15, 2026 · @Aishika Bhattacharya

At a glance

Own the **hands-on validator** lane: you are the only person on the panel whose day job is independently challenging models, so your value is "what validation actually looks like for GenAI" (Q3, Q7, Q8), not framework theory.

- **Session:** Day 1, 21 October 2026; 40 min discussion + 5 min Q&A; slot TBC
- **Airtime:** 8 panellists + moderator in 40 min = roughly 4–5 minutes each in total. Expect 2–3 turns of 60–90 seconds. Prepare 3 strong points, not 10.
- **Moderator:** Minhaj Ahmed (Product Leader, HSBC)

Panellist	Likely lane	Overlap risk with you
Soung Low, NatWest (Senior Model Risk Data Scientist)	Technical testing, LLM evaluation metrics	**High** on Q3 — split as "what we test" (you) vs "how we build the test harness" (Soung)
Liam Davies, Lloyds (MRM Lead)	Framework, policy, model definition, tiering	Medium on Q1 — you were in Lloyds retail validation, so coordinate stories
Nadim Akhtar, Barclays (AVP)	Likely business/first line use cases	Low
Adrian Mendez, Schroders (Head of Ops Risk & Control)	Non-bank view, operational risk, third-party	Medium on Q7
Anish Shah, NatWest Group (Accountable Auditor, Model Risk)	Third line, accountability, evidence	Medium on Q4
Chhavi Kakkar, NatWest (Control Intelligence & Automation)	Continuous control monitoring, automation	Medium on Q8 — you take model-performance monitoring, she takes control automation
You, Handelsbanken	Independent validation, AML/fraud, AI validation policy, UK + EU lens	—

Two things only you can bring: (1) a **mid-sized bank** view on proportionality, against three large-bank NatWest voices; (2) a **UK subsidiary of an EU (Swedish) group**, so you live with both the PRA's tech-agnostic SS1/23 approach and the EU AI Act.

Your agenda title reads "Senior Model Validator". If you prefer "Model Risk Management Senior Analyst", ask the organisers before the programme prints.

Your positioning and signature themes

Your 20-second intro: *"I'm an independent model validator at Handelsbanken UK. Before that I validated models at Lloyds and Morgan Stanley, including AI/ML models where explainability testing was the core of the work, and I started out building AML models at Citi and HSBC. Today I validate financial crime and fraud models, and I'm helping shape our AI validation policy."*

Carry three themes through every answer, so the audience remembers one clear voice:

1. **Validate the system, not just the model.** With GenAI the risk sits in the whole chain: prompt, retrieval data, guardrails, foundation model version, and the human who acts on the output. Inventory and validate the use case as a system.
2. **Evidence beats explanation.** You often can't explain *why* an LLM said something. You can evidence *how often* it is right, wrong or harmful, against a defined test set, and keep proving it after go-live.
3. **Proportionality is a design choice, not a loophole.** Tier by use case and decision impact. An internal summarisation tool and a customer-facing credit assistant should not get the same validation, and a mid-sized bank cannot afford to pretend otherwise.

Credibility anchors from your career (use one per answer, not all at once):

- Developer turned validator: you know what developers leave out of documentation
- AI/ML explainability testing at Morgan Stanley: a bridge from "traditional ML" to GenAI
- AML transaction monitoring (Citi, HSBC, now Handelsbanken): high-volume, alert-driven, regulator-sensitive — a natural GenAI use case (alert triage, narrative drafting)
- Drafting an AI validation policy now: you've had to answer "is this a model?" for real
- Using LLMs yourself for drafting committee minutes from recordings: a low-risk use case that still needs human review

Question-by-question talking points

Volunteer to **lead Q3 and Q7**, and offer short builds on Q2, Q5 and Q8. Pass the rest unless Minhaj comes to you. Each question below has the context behind it, a full spoken answer (about 2 minutes; trim to 60–90 seconds on the day), supporting detail for follow-ups, and

who to hand over to.

#	Question (short)	Your role	Natural owner
1	Redefining model risk; framework gaps	Build	Liam (MRM Lead)
2	New risks from non-deterministic outputs	Build	You or Soung
3	Validating for accuracy, hallucination, bias	**Lead**	You
4	Responsibility for decisions	Pass / one line	Anish (audit)
5	Rigour vs speed	Build	You or Liam
6	Human oversight	Build (AML angle)	Nadim / Adrian
7	Third-party and foundation models	**Lead**	You
8	Post-deployment monitoring	Build	Chhavi / Soung
9	Cross-team governance	Pass / one line	Adrian
10	Priorities for the future	Closing line	Everyone

Q1. How is GenAI changing the definition of model risk, and where do existing frameworks fall short?

Your role: build on Liam. Let him do the framework overview; you add what breaks in validation practice.

The context

Model risk management grew up around models that turn numbers into numbers: PD scorecards, IRRBB and NII projections, AML thresholds. US SR 11-7 (2011) set the template; the PRA's SS1/23 (effective May 2024) is the UK version, with five principles: model identification and classification, governance, development and use, independent validation, and risk mitigants.

The classic definition of model risk is the potential for loss from decisions based on incorrect or misused model outputs. That has two sources: the model is **wrong** (fundamental error) or **misused** (right model, wrong use). GenAI keeps both, but each now looks different:

- **Wrong** now includes outputs that are fluent and plausible but false (hallucination), and outputs that differ every time you ask.

- **Misused** now includes thousands of staff using a general-purpose tool for purposes nobody validated, because the same chatbot can summarise a policy, draft a credit memo or answer a customer.

The question underneath Q1 is: *is a GenAI tool a "model" at all?* SS1/23's definition is deliberately wide. It allows qualitative inputs and outputs, and the PRA has said the principles were written with AI in mind. So most UK practitioners now say yes, GenAI is in scope; the debate has shifted to *how* to manage it proportionately.

Your full answer (spoken)

> "I'd say the definition of model risk hasn't changed, but where it lives has. The classic question was: is the model wrong, or is it being misused? Both still apply. What's new is that with GenAI, a model can be wrong in a convincing way. It produces a fluent, confident answer that simply isn't true. And it can be misused at scale, because one general-purpose model can be pointed at a hundred different tasks by people who never spoke to model risk.
>
> The regulatory definition is broadly fine. SS1/23 already covers qualitative outputs and was written to be technology-agnostic. Where frameworks fall short is in the operating assumptions underneath. Our inventories assume one model, one owner, one version, one dataset. Our validation assumes we can rebuild the model or at least re-perform its output. Our monitoring assumes the inputs are stable and the model doesn't change unless someone changes it.
>
> GenAI breaks all three. The behaviour depends on the prompt, the retrieved documents, the guardrails and the vendor's model version, and any of those can change without anyone touching 'the model'. So the practical shift I'd argue for is to inventory and validate the **use case as a system**, with the foundation model recorded as one component, and to tier by what the output is used for, not by the technique."

Supporting detail

Where existing frameworks fall short, element by element:

Framework element	Traditional assumption	What GenAI breaks	Practical adaptation
Model identification	A model has a clear boundary and purpose	One foundation model serves many uses; staff can create new uses through prompts alone	Record **use cases**; link each to the underlying model; capture shadow use through intake and attestation

Framework element	Traditional assumption	What GenAI breaks	Practical adaptation
Tiering	Based on materiality and complexity	Materiality depends on the use, not the model; complexity is always "high"	Tier by decision impact, customer exposure and autonomy (advise vs act)
Documentation	Developer explains methodology and data	Vendor won't disclose training data or architecture	Document the system design: prompts, retrieval sources, guardrails, test results, vendor evidence
Replication	Validator rebuilds or re-performs	Impossible; outputs vary run to run	Evidence-based testing against a labelled test set, measured as distributions
Performance metrics	Gini, RMSE, hit rates	No single metric for text quality	Task-specific metrics: groundedness, accuracy, refusal rate, consistency, toxicity
Change management	Changes are deliberate and logged	Vendor updates, prompt edits and new documents change behaviour silently	Version-pin; treat prompt and vendor changes as model changes
Ownership	One model owner	Platform team, vendor, business user and data owner all share it	Named owner per use case plus a platform owner

If someone pushes back ("isn't this just technology risk, not model risk?"): it is both. Technology risk covers availability, security and access. Model risk covers whether the *output* is fit for the decision. A perfectly secure, always-available chatbot that gives wrong answers is a model risk problem.

Your experience link: at Morgan Stanley you validated AI/ML models where explainability testing was central. You can say the step from ML to GenAI is bigger than the step from regression to ML, because you lose replication as well as interpretability.

Hand-offs: Liam (Lloyds MRM Lead) will likely cover framework and policy; open with "Building on Liam's point, from the validation side…". Anish (audit) may raise inventory completeness; agree and add the shadow-use angle.

Q2. What new risks arise when outputs are probabilistic, non-deterministic and hard to explain?

Your role: build, or lead if Minhaj comes to you first. Soung may take the technical side; you take the "what does this mean for a bank" side.

The context

Three properties of GenAI are behind this question:

- **Probabilistic:** a large language model (LLM) generates text by predicting the next word from a probability distribution. It is not looking up facts; it produces the most likely-sounding continuation. That is why it can be fluent and wrong at once.
- **Non-deterministic:** the same prompt can produce different answers, because of sampling settings ("temperature"), small changes in context, or infrastructure effects. Even at temperature zero, outputs from hosted models are not guaranteed identical.
- **Hard to explain:** models have billions of parameters. Techniques banks used for ML explainability (SHAP values, feature importance, partial dependence) don't translate meaningfully to free text. An LLM can produce a reasoning trace, but that trace is generated text too, not a guaranteed account of how it reached the answer.

For banks this collides with existing obligations: explaining credit decisions to customers, Consumer Duty's focus on good outcomes and consumer understanding, record-keeping for audit, and the general expectation that a firm can reproduce and justify what it did.

Your full answer (spoken)

> "I'd group the new risks into four, plus one human risk that I think is the most underrated.
>
> First, **hallucination**: the model states something false with complete confidence. In a bank that might be an invented policy clause, a wrong figure in a summary, or a regulation that doesn't exist.
>
> Second, **instability**: ask the same question twice and you can get two different answers. That's a problem for consistent customer treatment, and for audit, because you may not be able to reproduce what the customer was told.
>
> Third, **prompt sensitivity and manipulation**: small wording changes shift the output, and deliberately crafted inputs, prompt injection, can make the model ignore its instructions or leak information. That's partly a security risk, but it shows up as model risk because the output is wrong.
>
> Fourth, **silent change**: if you use a vendor model, the provider can update it, and behaviour shifts without any change on your side.
>
> And the human one: **automation bias**. Fluent, well-formatted text is persuasive. The better the model gets, the less carefully people check it, so the control you relied on, human review, quietly weakens.
>
> One reassurance from the validation side: non-determinism isn't new to us. We validate simulation and Monte Carlo models all the time. We stop testing single outputs and start testing the distribution of outcomes: how often is it right, how often is it wrong, and how bad is wrong."

Supporting detail

Risk	What it looks like in a bank	How you'd evidence or control it
Hallucination	Invented policy wording in an internal Q&A tool; wrong transaction amount in an alert summary	Groundedness testing against source documents; require citations; restrict answers to approved sources
Instability	Two customers with identical queries get different answers	Repeat-run consistency tests (same prompt N times, measure agreement); lower temperature; log every output

Risk	What it looks like in a bank	How you'd evidence or control it
Prompt injection	A customer email contains hidden text instructing the model to approve a request	Red-team testing; input filtering; separate system instructions from user content; limit what the model can act on
Data leakage	Model reproduces confidential or personal data in an answer	Access controls on retrieval; output filters; data protection review
Bias	Different tone or quality of answer by customer name, language or segment	Paired-prompt tests that vary only one characteristic
Silent change	Vendor update changes refusal behaviour or accuracy	Version pinning; regression testing on every update
Automation bias	Reviewers approve outputs without reading the source	Measure override rates; seed known errors and check they are caught
Explainability gap	Cannot tell a customer why a decision was reached	Keep GenAI out of the decision itself, or use it only where the reason can be grounded in source data

On explainability, a nuance worth saying: for GenAI, the useful question is often not "why did the model say this?" but "can we show this statement is supported by the source?" That is **traceability** rather than explainability, and it is testable.

Your experience link: at Morgan Stanley your explainability testing on ML used methods like feature attribution. Those gave a partial window into the model; with LLMs that window largely closes, so evidence of outcomes has to carry more weight.

Hand-offs: Soung can go deeper on why outputs vary and on technical mitigations. Adrian may pick up prompt injection and data leakage as operational risks; let him.

Q3. How should banks validate and monitor GenAI for accuracy, hallucination, bias, reliability and unexpected behaviour?

Your role: lead. This is the question the audience will expect the validator to answer, and where you have most credibility.

The context

Traditional independent validation has a familiar shape: review conceptual soundness (is the methodology right for the purpose?), check data quality, replicate or benchmark the model, test performance (discrimination, calibration, stability), run sensitivity tests, and review implementation and ongoing monitoring. SS1/23 Principle 4 sets this out as the expectation of independent challenge.

With GenAI, several of these steps can't be done in their usual form:

- **Replication** is impossible: you can't retrain a foundation model, and outputs vary.
- **Conceptual soundness** of the core model can't be assessed: you don't have the training data or architecture.
- **Standard metrics** don't exist: there is no Gini coefficient for a paragraph.

The industry direction (also reflected in the BoE/FCA AI Consortium's June 2026 discussion) is **outcome-based validation of the whole system**: define what good looks like for the specific use, build evidence that the system meets it, and keep proving it after go-live.

Key terms you may use or hear:

- **Golden (reference) test set:** a curated set of inputs with known correct answers, used to score the system.
- **Groundedness / faithfulness:** whether each claim in the output is supported by the source documents provided.
- **RAG (retrieval-augmented generation):** the model first retrieves relevant documents (e.g. policies) and answers from them. Most bank use cases are RAG, which helps validation because there is a source to check against.
- **Red-teaming:** deliberately trying to make the system fail or misbehave.
- **LLM-as-a-judge:** using a second model to score outputs at scale; it needs calibrating against human scores.

Your full answer (spoken)

> "The honest starting point is that we can't validate a GenAI model the way we validate a regression. We can't rebuild it, we often can't see inside it, and it won't give the same answer twice. So validation has to shift from **re-performance to evidence**. I'd break it into four steps.
>
> **One, define fitness for purpose before you test anything.** What decision does this output feed? Who sees it? What's a tolerable error rate? A two percent hallucination rate might be fine for drafting internal notes and completely unacceptable for something a customer reads. Without that definition, any metric is just a number.
>
> **Two, build a test set from real cases.** A labelled set of inputs with known right answers, including the awkward ones: edge cases, ambiguous questions, questions it should refuse, and adversarial prompts. Then measure accuracy, groundedness against the source documents, whether it refuses when it should, and consistency across repeated runs. We report these as distributions, not single results.
>
> **Three, test bias by outcome.** You usually can't inspect the training data, but you can test behaviour: paired prompts identical except for a name, a nationality or a language, and check whether quality or tone changes.
>
> **Four, challenge the controls, not just the model.** Red-team the guardrails. Check for data leakage. And test the human in the loop: seed known errors into the outputs and see whether reviewers actually catch them. If they don't, that control isn't working.
>
> Conceptual soundness still matters, it just moves. Instead of challenging the maths, we challenge the design: why this model, why this prompt, why these retrieval sources, why this level of autonomy.
>
> And validation doesn't end at approval. The same test set becomes the regression suite you re-run on a schedule and every time the vendor updates the model."

Supporting detail

How the traditional validation steps translate:

Traditional validation step	GenAI equivalent
Conceptual soundness of methodology	Design review: model choice, prompt design, retrieval sources, guardrails, autonomy level, fallback
Data quality review	Quality and currency of retrieval documents; test set representativeness; personal data handling

Traditional validation step	GenAI equivalent
Replication / benchmarking	Benchmark against alternative models or the current manual process on the same test set
Performance testing	Accuracy, groundedness, completeness, refusal rate, latency, by task and segment
Stability / sensitivity	Repeat-run consistency; prompt paraphrase tests; behaviour under noisy or long inputs
Stress testing	Adversarial and red-team prompts; prompt injection; out-of-scope questions
Bias / fairness	Paired-prompt testing across customer characteristics; tone and quality comparison
Implementation testing	Logging, version pinning, access control, output filters working as designed
Ongoing monitoring plan	Scheduled re-runs of the test set; sampled human review; drift and complaint signals

Specific metrics you can quote (pick two):

- **Accuracy:** share of answers judged correct against the reference answer
- **Groundedness:** share of claims supported by retrieved sources (the inverse is a hallucination rate)
- **Completeness:** did the summary include the facts that matter (critical for alert summaries)
- **Refusal accuracy:** refuses out-of-scope or unsafe requests, without over-refusing legitimate ones
- **Consistency:** agreement rate across, say, 10 repeated runs of the same prompt
- **Reviewer catch rate:** share of seeded errors caught by human reviewers

If asked "how big should the test set be?": big enough to estimate the error rate with useful confidence for the tier. A few hundred labelled cases is a common starting point for a material use case, weighted towards the cases that matter most. Building and maintaining it is real work, and business subject-matter experts must be involved.

On LLM-as-a-judge: acceptable for scale if you calibrate the judge against human labels and report agreement. It is a model too, so it needs proportionate review.

Your experience link: an AML example works well. If GenAI summarises a transaction-monitoring alert for an investigator, fluency isn't the test. The test is **completeness**: does it ever leave out the one fact that should have escalated the case? You test that with

seeded cases where you know the critical fact. Keep it generic; don't name models.

Hand-offs: agree the split with Soung in advance: you cover **what to test and why**, Soung covers **how to build the evaluation tooling**. Close with "Soung can say more about how you build that at scale."

Q4. When GenAI is integrated into critical processes, how should responsibility for its decisions and outputs be established?

Your role: short build. Anish (accountable auditor) is the natural owner; you add the validator's view of where accountability blurs in practice.

The context

UK banks already have a clear accountability structure, and none of it switches off for AI:

- **SM&CR (Senior Managers and Certification Regime):** named senior managers are personally accountable for their areas. Regulators have repeatedly pointed to SM&CR as the main route to AI accountability, rather than new AI-specific rules.
- **SS1/23 Principle 2:** the board sets model risk appetite, and firms are expected to identify a senior manager (SMF) with overall responsibility for the model risk management framework.
- **Three lines of defence:** the first line (model owners and users) owns the risk; the second line (model risk management, validation) gives independent challenge; the third line (internal audit) gives assurance on the whole.
- **Consumer Duty:** where customers are affected, the firm remains responsible for outcomes whatever technology produced them.
- **EU AI Act:** separates the **provider** (who builds or places the AI system on the market) from the **deployer** (who uses it). A bank using a vendor model is usually the deployer, with its own obligations, and can become a provider if it substantially modifies the system.

What makes GenAI harder is that responsibility is spread across more parties. One use case might involve a foundation model vendor, an internal platform team that hosts it and sets guardrails, a data owner whose documents it retrieves, the business unit that uses it, and the employee who acts on the output. When something goes wrong, each can point at another.

Your full answer (spoken)

> "I'd keep this simple, because I think the answer is the same as for any model. The first line owns the use and the outcome. Model risk provides the independent challenge. A named senior manager is accountable. And you can't outsource accountability to a vendor, however good their model is.
>
> Where it gets blurred in practice is that a GenAI use case has more hands on it than a traditional model: the vendor, the platform team who host it and set the guardrails, the people who own the documents it reads, and the business user. So from a validation point of view, the first thing we ask is: who is the **named owner of this use case**, and does that person understand what the system can and can't do?
>
> The second point: 'human in the loop' shouldn't become a way of moving accountability onto the most junior person in the chain. If a reviewer is expected to catch the model's errors, the owner has to show that the reviewer realistically can, with the time, training and information to do it."

Supporting detail

A practical RACI for a GenAI use case (useful if Minhaj asks "what does that look like?"):

Party	Responsible for
Use-case owner (first line, business)	Purpose, acceptable use, outcomes, ongoing performance, sign-off to deploy
Platform / technology owner	Hosting, version control, guardrails, logging, access, availability
Data / content owner	Accuracy and currency of documents the system retrieves
Vendor	Contractual commitments: change notice, evidence, data handling, incident reporting
Model risk management (second line)	Inventory, tiering, independent validation, approval conditions, monitoring oversight
Compliance, data protection, conduct	Regulatory, privacy and customer-outcome review
Internal audit (third line)	Assurance over the framework and how it operates
Accountable SMF	Overall accountability; reports to the board on AI and model risk

Points of tension worth knowing:

- **Model owner vs model user:** a central GenAI platform used by ten business areas has one technical owner but ten different risk profiles. Ownership should sit at the use-case level.
- **Agentic AI raises the stakes:** when a model *acts* (sends an email, updates a record, initiates a payment) rather than advises, accountability becomes urgent. The BoE/FCA AI Consortium has discussed action limits and kill switches for higher-risk agents.

Hand-offs: "Anish will have a sharper view on how audit tests whether that accountability is real." Adrian (Schroders) may add the asset-manager and operational risk angle.

Q5. How can banks balance rigorous validation with the speed at which GenAI evolves?

Your role: build (or lead if Liam takes Q1 at length). This is where your mid-sized bank perspective is most useful.

The context

The tension is real on both sides:

- **Speed:** foundation models are updated every few months; new capabilities (longer context, agents, multimodal input) arrive faster than a traditional validation cycle of several weeks to months. Business areas see competitors moving and push to deploy.
- **Rigour:** a validation queue that can't keep up creates two bad outcomes. Either MRM becomes a bottleneck and is bypassed (shadow AI: staff using public tools informally), or standards are quietly lowered to clear the queue.

SS1/23 is explicitly **proportionate**: validation intensity should match model tier (materiality and complexity). The PRA's October 2025 CRO roundtables discussed tiering and independent validation specifically for AI, and most participants did not ask for new AI-specific rules, preferring to apply existing principles proportionately. So the regulatory room to be pragmatic exists; the question is how to use it well.

Your full answer (spoken)

> "I'd push back slightly on the framing. Rigour and speed aren't really opposites; what's slow is applying the same heavyweight process to everything. So I'd suggest three things.
>
> **First, tiered pathways.** A low-risk internal use, say summarising documents for an employee who then checks them, with no customer impact and no decision attached, can go through a light pre-use review: defined controls, a short test, a named owner, and monitoring. A use that touches customers or feeds a credit or fraud decision gets full validation. Proportionality isn't doing less; it's doing the right amount in the right place.
>
> **Second, validate patterns, not just instances.** Most bank GenAI use cases share an architecture: a model, a retrieval layer, guardrails, logging. Validate that pattern properly once, and the next use case only needs validating for what's different: its data, its prompts, its purpose. That's how you get faster over time without cutting corners.
>
> **Third, conditional approval.** Rather than a binary pass or fail, approve with conditions: limited scope, tighter monitoring thresholds, a review date. That gets value into the business while the evidence builds, and keeps model risk in the conversation instead of being the team people work around.
>
> From a mid-sized bank's perspective, proportionality isn't optional. We can't match the resources of the largest banks, so we have to be deliberate about where validation effort goes."

Supporting detail

An example of tiered pathways (illustrative, not any specific bank's policy):

Tier	Typical uses	Review depth	Typical turnaround
Low	Internal drafting, summarisation, coding assistance, with human review and no decision attached	Pre-use checklist, standard controls, owner attestation, light sample test	Days
Medium	Internal decision support (e.g. analyst research, alert triage support), not customer-facing	Targeted validation of test results, guardrails and reviewer effectiveness	Weeks

Tier	Typical uses	Review depth	Typical turnaround
High	Customer-facing, feeds credit / fraud / AML decisions, or acts autonomously	Full independent validation, red-teaming, bias testing, conditional approval, enhanced monitoring	Weeks to months

Say "illustrative" if you use this, so it isn't taken as Handelsbanken's policy.

Other levers:

- **Reusable test assets:** shared test sets, red-team prompt libraries and evaluation scripts across use cases
- **Early engagement:** MRM involved at design means findings arrive when they're cheap to fix
- **Clear materiality triggers:** a defined list of changes that need re-validation (new vendor version, new data source, customer exposure) vs changes that only need notification
- **Sandboxing:** controlled experimentation with synthetic or non-sensitive data before formal validation

Your experience link: you're helping write an AI validation policy, so you can say: "When you write the policy, the hardest part isn't the high-risk end; it's deciding what the light-touch path looks like and making sure it still has teeth."

Hand-offs: Liam may cover policy design; you add the practitioner view. Nadim (Barclays) may represent the business wanting speed; acknowledge it rather than defend MRM.

Q6. What role should human oversight play in credit decisions, fraud detection, customer service and financial analysis?

Your role: build, with the fraud and AML angle. Nadim or Adrian may lead on business use.

The context

"Human oversight" comes in three common forms, and it helps to name them:

- **Human-in-the-loop:** a person approves each output before it takes effect (e.g. an investigator reviews every alert summary).
- **Human-on-the-loop:** the system acts, and a person monitors and can intervene (e.g. sampling customer chatbot conversations).
- **Human-out-of-the-loop:** fully automated, with oversight only through monitoring and periodic review.

The four areas in the question carry very different risk:

Area	Regulatory sensitivity	Typical GenAI role today
Credit decisions	High: explainability to customers, fair treatment, Consumer Duty; creditworthiness assessment of individuals is a **high-risk** use under the EU AI Act; UK data protection law requires safeguards for significant automated decisions, including human intervention	Supporting analysis and documentation (e.g. drafting credit memos), not making the decision
Fraud and AML	High operationally (missed fraud, regulatory breach), lower customer-facing explainability; fraud detection is carved out of the EU AI Act's high-risk credit category	Alert triage support, case summaries, narrative drafting for suspicious activity reports, investigator assistance
Customer service	Conduct risk, Consumer Duty, vulnerable customers, complaints	Chatbots, agent assist, drafting responses
Financial analysis	Lower direct customer risk, but decisions may be material	Research summaries, document extraction, drafting

The catch: human oversight is often treated as the control that makes everything acceptable, without evidence that it works. Research on automation bias shows reviewers increasingly defer to fluent automated outputs over time. The BoE/FCA AI Consortium also noted that human-in-the-loop review isn't always practical at scale.

Your full answer (spoken)

> "Human oversight is essential, but I'd challenge the idea that putting a human in the loop automatically makes something safe. From a validation point of view, human review is a control, and like any control, we need evidence it works.
>
> Take my area, financial crime. GenAI is genuinely useful for summarising a transaction-monitoring alert or drafting a case narrative. It can save investigators real time. But the decision whether to escalate or close stays with the investigator. And the risk isn't that the summary is badly written; it's that it's well written and leaves out the one fact that mattered, and a busy investigator trusts it.
>
> So when we review a use case with human oversight, we ask: does the reviewer have the time and the source information to actually check? What's the override rate? If someone accepts 99.9 percent of outputs, that's not oversight, it's a rubber stamp. The strongest test is simple: seed some known errors and see whether they get caught.
>
> For credit decisions specifically, I'd keep GenAI in a supporting role, drafting or summarising, not deciding. Explainability expectations and Consumer Duty make it very hard to justify a decision you can't explain.
>
> The level of oversight should match the risk: in-the-loop for high-impact decisions, on-the-loop with sampling for lower-risk, high-volume uses like internal Q&A."

Supporting detail

How to evidence that oversight works:

- **Override / edit rate:** how often reviewers change or reject outputs. Too low can mean rubber-stamping; too high means the tool isn't fit for purpose.
- **Seeded-error testing:** insert outputs with known errors and measure the catch rate.
- **Time on task:** if review time per item falls sharply after go-live, reviewers may be skimming.
- **Source access:** does the reviewer see the underlying data (transactions, documents) or only the summary?
- **Training and guidance:** do reviewers know the system's known failure modes?
- **Escalation path:** what happens when a reviewer disagrees, and is that captured as monitoring data?

Vulnerable customers: in customer service, GenAI must recognise vulnerability signals and route them to a human. That is a specific test case to include in validation.

Your experience link: your AML background (development at Citi and HSBC, now validating TM and fraud models) gives you authority to say what investigators actually need. Keep it generic.

Hand-offs: Nadim may cover customer-facing deployment. Chhavi's control-monitoring angle connects naturally to measuring override rates automatically.

Q7. How should banks approach third-party and foundation models with limited visibility into training data, architecture or development?

Your role: lead. Validating vendor models with limited transparency is everyday work for a validator, especially in AML and fraud, where vendor systems are common.

The context

A **foundation model** is a large general-purpose model (e.g. the LLMs from OpenAI, Anthropic, Google, Meta, Mistral) trained on vast data and adapted to many tasks. Almost no bank trains its own; they access them through an API, a cloud platform, or embedded in vendor software (the CRM, the document tool, the coding assistant). That creates three layers of opacity:

- **Training data:** unknown, so you can't fully assess bias, data rights or relevance to your domain.
- **Architecture and weights:** proprietary, so no direct inspection.
- **Change:** the vendor controls updates and deprecation; your validated model can be replaced or retired on the vendor's timetable.

The regulatory position:

- **SS1/23** applies to vendor and third-party models as well as in-house ones; limited transparency doesn't remove the expectation of independent validation, though its form adapts.
- **PRA SS2/21** (outsourcing and third-party risk management) covers due diligence, contractual rights (including audit and access), and exit planning for material arrangements.
- **The UK critical third parties regime** lets HM Treasury designate systemic providers (initially cloud) for direct regulatory oversight.
- **The BoE/FCA AI Consortium** has made concentration risk from third-party model providers a primary workstream; its June 2026 discussion located concentration mainly at the model and compute level.
- **EU angle (relevant to a Swedish group):** the EU AI Act places obligations on providers of **general-purpose AI models** (applying since August 2025), including technical documentation for downstream users and a public summary of training content. **DORA**

(applying since January 2025) governs ICT third-party risk for EU financial entities.

Your full answer (spoken)

> "My starting point is that limited visibility doesn't lower the bar. It changes what evidence we accept.
>
> This isn't new for validators. In financial crime, a lot of transaction-monitoring and fraud systems are vendor products, and we've always had to validate them without seeing every line of code. GenAI is the same discipline with even less transparency.
>
> I'd think about it in four parts.
>
> **First, ask for everything you can get.** Model cards, the vendor's own evaluation results, known limitations, data-handling commitments, and critically, notice of changes. That belongs in the contract, along with testing rights. In the EU, foundation model providers now have documentation obligations to downstream users, which helps.
>
> **Second, shift the weight to outcome testing.** We can't see the training data, but we can test behaviour: our own test set, on our own data, for our specific use case. The vendor's benchmark tells you how the model does on the vendor's chosen tests. It isn't our validation.
>
> **Third, control change.** Pin the model version where you can, and treat a vendor update as a model change that triggers re-testing. The regression test set from validation is what makes that quick.
>
> **Fourth, plan for exit.** A handful of providers sit underneath most of the industry. If the model is withdrawn, changes materially, or the provider has an outage, what's your fallback? Can you switch models, and have you tested that the alternative performs acceptably?
>
> To sum it up: you can't validate the foundation model, but you can validate your use of it."

Supporting detail

Evidence checklist for a third-party GenAI model:

Area	What to request or test
Vendor documentation	Model card, intended use and limitations, evaluation results, safety testing, known failure modes

Area	What to request or test
Training data	Summary of data sources, cut-off date, IP and personal data position, exclusions
Change management	Version pinning, advance notice of updates and deprecation, release notes
Data handling	Whether your prompts and data are retained or used for training; data residency; encryption
Contractual rights	Testing and audit rights, incident notification, service levels, exit and transition support
Your own testing	Use-case test set, bias tests, red-teaming, consistency, performance vs alternatives
Concentration	Which other services depend on the same provider; substitutability; fallback tested
Embedded AI	GenAI features switched on inside existing vendor software (often without a project) captured in the inventory

A nuance that impresses practitioners: embedded GenAI. Vendors are adding GenAI features into existing software (CRM, document management, case management, even AML platforms) through routine upgrades. These often bypass model risk entirely because no one starts a "model project". Inventory and third-party processes need a trigger for this.

Fine-tuning and RAG: if the bank fine-tunes a foundation model or builds retrieval on top, it takes on more design responsibility (and under the EU AI Act, substantial modification can shift a deployer towards provider obligations). Validation scope expands accordingly.

Your experience link: vendor model validation in AML is your strongest bridge. As a UK subsidiary of an EU group, you can also mention the dual view: UK principles-based (SS1/23, SS2/21) and EU rules-based (AI Act, DORA).

Hand-offs: Adrian (Schroders, ops risk and control) may add third-party risk management and outsourcing; let him take contract and supplier detail. Anish may ask about evidence quality for audit.

Q8. What are the most effective ways to monitor GenAI continuously after deployment?

Your role: build. Chhavi (control monitoring automation) and Soung (data science) are natural co-owners; you take *what* to monitor and *when to act*.

The context

Traditional model monitoring tracks a fixed set of metrics against thresholds: population stability (PSI), discrimination (Gini/AUC), calibration, override rates, and for AML models, alert volumes and productivity. Breaches trigger review or re-validation.

GenAI monitoring is harder for three reasons:

- **No ground truth in production:** for a chatbot or summariser, you don't automatically learn whether each output was right. You have to create that signal through sampling, feedback or automated scoring.
- **Behaviour changes without a release:** vendor model updates, new documents in the retrieval index, new kinds of user questions, and prompt edits all shift behaviour.
- **Volume and unstructured output:** thousands of free-text outputs a day can't all be reviewed by people.

Why regulators care: the PRA's October 2025 roundtables named ongoing monitoring as a key AI topic, and the AI Consortium has raised how fast problems can spread through shared AI dependencies.

Your full answer (spoken)

> "I'd think of GenAI monitoring as watching three things: what goes in, what comes out, and what it depends on.
>
> **What goes in:** are users asking the kinds of questions the system was validated for? If a tool built for policy Q&A starts getting questions about individual customer cases, that's scope creep, and it's a model risk signal even if nothing has technically gone wrong yet.
>
> **What comes out:** you can't review every output, so you sample. A regular sample scored by people, backed by automated checks at scale for groundedness, refusals and toxicity. Plus the signals you already have: complaints, user feedback, and how often reviewers override the output.
>
> **What it depends on:** the vendor model version, the freshness of the documents it retrieves, the guardrail configuration. Any change there should be detected and logged automatically.
>
> The most useful single practice, in my view, is to **re-run your validation test set on a schedule and on every change.** It's regression testing for the model. If performance on the test set moves, you know before your customers do.
>
> And as with any model, decide in advance what you'll do. Amber: increase sampling and investigate. Red: restrict scope, fall back to the manual process, or switch it off. If those thresholds and actions aren't agreed before go-live, they're very hard to agree in the middle of an incident."

Supporting detail

A GenAI monitoring framework (if asked for specifics):

Dimension	Example metrics	Source	Typical frequency
Input drift	Topic mix of queries; share of out-of-scope queries; new user groups	Query logs, topic classification	Weekly / monthly
Output quality	Accuracy and groundedness on sampled outputs; hallucination rate	Human review sample, LLM-as-a-judge	Weekly / monthly
Safety	Toxicity, data leakage, policy-violating outputs, prompt-injection attempts	Automated filters, security logs	Continuous

Dimension	Example metrics	Source	Typical frequency
Refusal behaviour	Over- and under-refusal rates	Logs, sampled review	Monthly
Human oversight	Override and edit rates; time on review; seeded-error catch rate	Workflow data	Monthly
Customer signals	Complaints, escalations, satisfaction	Complaints and CRM data	Monthly
Dependencies	Vendor version changes, retrieval index updates, prompt changes	Change logs, automated alerts	On change
Regression	Score on the validation test set	Scheduled evaluation run	Monthly and on every change
Operational	Latency, availability, cost per query	Platform telemetry	Continuous

Thresholds and actions (example):

- **Green:** within tolerance; routine reporting to the model owner and MRM
- **Amber:** e.g. test-set groundedness drops by a defined margin, or override rate moves outside its band. Action: increased sampling, root-cause review, report to the model risk committee
- **Red:** material breach or incident. Action: restrict use, revert to the previous version or manual process, trigger re-validation

Logging is the foundation: without full logging of prompts, retrieved documents, model version and outputs, you can neither monitor nor reconstruct what a customer was told. Make it a precondition for approval.

Your experience link: draw the parallel with AML monitoring of alert volumes and conversion rates: a sudden shift signals something changed upstream. GenAI input-drift monitoring is the same idea.

Hand-offs: "Chhavi will know far more about how you automate this so it isn't a manual exercise." Soung may cover automated evaluation methods.

Q9. How can risk, compliance, technology and business teams govern GenAI together without slowing responsible adoption?

Your role: short build. Adrian (ops risk and control) or Liam are likelier leads; you add the "engage MRM early" point from the validation side.

The context

GenAI cuts across more functions than any traditional model. A single use case can need sign-off from model risk, data protection (DPIA), information security, third-party risk, compliance and conduct, legal (IP, contracts), operational resilience, and the business. Each has its own process, form and timeline. Run one after another, approval can take months, and teams either give up or route around governance.

Common responses across the industry:

- **AI governance committees or councils** with cross-functional membership
- **A single intake ("front door")** for AI use cases that triages and routes to the right reviews in parallel
- **AI risk taxonomies** that map each risk (model, data, conduct, security, third-party) to an owning function, so nothing is reviewed twice or not at all
- **AI literacy** programmes so business owners understand what they're accountable for (the EU AI Act includes an AI literacy obligation, applying since February 2025)

Your full answer (spoken)

> "From where I sit, the single biggest thing is timing. The most expensive validation finding is the one that arrives after the build is finished. If model risk sees a use case for the first time at go-live, every finding feels like a blocker. If we're involved at design, the same point is just a design choice.
>
> Practically, I'd argue for one front door. One intake for any AI use case, which captures the purpose, the data, the vendor and the customer impact once, and then routes it to model risk, data protection, security, third-party and compliance in parallel, not one after another. Each function knows what it owns, so things aren't reviewed twice, or worse, not at all.
>
> The other piece is shared language. If business owners understand what tiering means and what evidence a validator will ask for, they can build it in from the start. That makes the whole process faster, and frankly better."

Supporting detail

Who typically owns what in GenAI governance:

Risk type	Typical owning function
Model risk (output fitness, validation, monitoring)	Model risk management
Personal data, DPIA, automated decision rights	Data protection / DPO

Risk type	Typical owning function
Prompt injection, data leakage, access, cyber	Information security
Vendor due diligence, contracts, exit, concentration	Third-party / procurement risk
Customer outcomes, Consumer Duty, vulnerable customers	Compliance and conduct risk
IP, licensing, contract terms	Legal
Availability, impact tolerances, important business services	Operational resilience
Overall AI strategy and risk appetite	AI governance committee / board

Things that slow adoption without adding safety (if you want to be candid):

- Sequential approvals where parallel would do
- Asking for the same information on six different forms
- Applying full validation to low-risk internal tools
- No clear definition of which changes need re-approval, so every tweak goes back to the start

Your experience link: your model inventory migration work gives you a practical point. An inventory that captures AI use cases with consistent fields (purpose, vendor, data, tier, owner) lets every function work from the same picture. Keep it general.

Hand-offs: Adrian (Schroders) will likely bring the operational risk and controls structure. Chhavi may talk about automating control evidence, which reduces the burden on business teams.

Q10. Looking ahead, what should banks prioritise now to build an MRM framework that keeps pace with the next generation of AI?

Your role: closing line. Minhaj will likely go round the panel for one priority each, so expect about 30 seconds.

The context

What "next generation" means in practice:

- **Agentic AI:** systems that plan and take actions across tools (send messages, update records, initiate payments) with less human involvement. The FCA's AI Live Testing second cohort (from April 2026, including Barclays and Lloyds) is testing agentic AI, with AML and KYC among the use cases.

- **Small and specialised models:** cheaper, domain-tuned models that banks may fine-tune or host themselves, bringing more design responsibility in-house.
- **Multimodal models:** working across text, images, voice and documents (e.g. reading scanned ID or call recordings).
- **AI everywhere:** GenAI embedded in standard enterprise software, so the number of AI use cases grows without anyone "launching" one.

The regulatory horizon:

- **UK:** no new AI-specific rules planned for now; AI is a 2026 PRA supervisory priority; the PRA says it will build on its MRM principles in 2026 and keeps its technology-agnostic approach under review; the AI Consortium is due to publish a report this year.
- **EU:** high-risk AI obligations (including creditworthiness assessment) now apply from **2 December 2027** following the Digital Omnibus, roughly 14 months from now.

Your closing line (pick one, about 30 seconds)

Option A: inventory (the foundation)

> "Know what you have. Most banks don't yet have a complete picture of where GenAI is being used, especially inside vendor software. An inventory that captures use cases, not just models, with an owner, a tier and a vendor for each, is the foundation for everything we've discussed today."

Option B: evaluation capability (the validator's choice) — *recommended, as it ties back to your Q3 lead*

> "Invest in evaluation capability now: test sets, red-teaming, automated scoring. That's what validation will run on for the next five years. Models will keep changing; a bank that can re-test quickly can adopt quickly and safely."

Option C: people and skills

> "Skills. We need validators who can challenge an LLM pipeline, not just a scorecard, and business owners who understand what they're accountable for. Frameworks are only as good as the people applying them."

Option D: agentic readiness

> "Get ready for agents now. Once AI starts taking actions rather than giving advice, the questions change: what is it allowed to do, what are the limits, and how do you stop it. Those controls should be designed before the first agent goes live, not after."

Supporting detail

If you get a longer slot, a three-part structure works:

1. **Foundations (now):** complete AI use-case inventory; tiering criteria for GenAI; clear policy on what is in scope; logging standards
2. **Capability (next 12 months):** reusable evaluation tooling and test sets; validator upskilling; vendor evidence standards and contract clauses; monitoring thresholds
3. **Readiness (next 2 years):** agentic AI controls (action limits, kill switches, permissions); EU AI Act high-risk compliance for in-scope uses ahead of December 2027; concentration and exit planning across AI vendors

The EU line (only if it fits): "For those of us in EU groups, the December 2027 deadline for high-risk AI is time to build, not time to relax."

Hand-offs: agree on the prep call that closing lines don't all say "inventory" or "governance". Offer to take evaluation capability (Option B) so yours is distinct.

Regulatory anchors to cite

The UK position in one sentence: no new AI rules; existing frameworks (SS1/23, SM&CR, Consumer Duty, operational resilience, third-party risk) apply, and AI is a named PRA supervisory priority for 2026. Cite one anchor per answer at most; executives tune out regulation lists.

Anchor	What to say	Use on
PRA SS1/23	Technology-agnostic MRM principles that "deliberately included factors relevant to the use of AI models"; covers vendor models too	Q1, Q7
BoE/PRA letter to the Chancellor, 1 April 2026	PRA keeps the tech-agnostic approach under review; plans to build on MRM principles in 2026; AI adoption is a 2026 supervisory priority; roundtables to be repeated	Q1, Q10

Anchor	What to say	Use on
PRA CRO roundtables on AI and MRM, October 2025	21 firms; topics included tiering, explainability, overfitting, independent validation and monitoring — i.e. exactly this panel's questions	Q3, Q5
BoE/FCA AI Consortium, June 2026 minutes	GenAI workshop proposed managing risk at the **whole-system level** with outcome-based validation and scorecards; agentic workshop proposed action limits and kill switches; concentration risk sits at model and compute level. Not binding.	Q3, Q7, Q8
FCA AI Live Testing, 2nd cohort from April 2026	Barclays and Lloyds are in it (your co-panellists' firms), testing agentic AI and small language models, incl. AML and KYC use cases; evaluation report due Q1 2027	Let Nadim / Liam speak to it
EU AI Act + Digital Omnibus	Stand-alone high-risk obligations (incl. creditworthiness assessment) pushed from 2 Aug 2026 to **2 Dec 2027**; embedded high-risk to 2 Aug 2028. Council gave final approval in mid-2026.	Q10, your EU-group angle

How to use the EU angle: *"As part of a Swedish group, we can't wait for the UK to decide. The EU AI Act already sets the direction, and the delay to December 2027 is time to build, not time to relax."*

One caution: check the Omnibus has been published in the Official Journal before stating it as "in force"; the sources I opened confirm Council approval, not publication.

Examples and soundbites

Panels reward one concrete example over five abstract points. Keep these generic: no model names, vendors or internal findings.

Examples you can tell in 30 seconds

- **The AML alert summary.** A GenAI tool drafts the case narrative for a transaction-monitoring alert. Low risk? Only if the investigator still reads the underlying transactions. The validation question is not "is the summary fluent" but "does it ever omit the fact that should have escalated the case?" Test that with seeded cases.
- **The meeting-minutes test.** Using an LLM to draft committee minutes from a recording: it saves hours, but it will occasionally attribute a comment to the wrong person or soften a challenge. Harmless for a team catch-up; material for a governance committee where the minutes are the audit trail. Same model, different tier.
- **The vendor update.** A third-party model is updated overnight with no code change on our side, and output behaviour shifts. In a traditional framework nothing triggered a revalidation. That is the gap Q1 and Q8 are about.
- **The "is it a model?" debate.** Writing an AI validation policy forces the question of whether a chatbot that only retrieves policy documents is a model. Practical answer: if its output informs a decision or reaches a customer, it is in scope, and the tier does the rest.

Soundbites (pick two, don't use all)

- "We used to validate the model. Now we validate the system around it."
- "You can't explain an LLM, but you can evidence it."
- "A vendor's benchmark is their marketing; our test set is our validation."
- "A human in the loop who approves everything is a rubber stamp, not a control."
- "Every vendor model update is a model change until proven otherwise."
- "Proportionality isn't doing less. It's doing the right amount in the right place."

Audience Q&A: likely questions

Five minutes means two or three questions. These are the ones most likely to land on a validator.

Likely question	Your short answer
"How do you measure hallucination in practice?"	Against a labelled test set: share of answers with a claim not supported by the source documents. Pair automated checks with human scoring on a sample, and track it over time, not once.

Likely question	Your short answer
"Is an LLM-as-a-judge acceptable for validation?"	As a scaling tool, yes, if the judge itself is calibrated against human labels and you report its agreement rate. It's a model, so it needs its own light-touch review.
"Should every GenAI tool go into the model inventory?"	Every use case should be recorded somewhere; not every one needs full validation. The inventory is how you see aggregate exposure to one vendor.
"What about agentic AI?"	It raises the stakes: the model acts rather than advises. Validate the permissions and limits as much as the model: what can it do, and what stops it. The AI Consortium has discussed kill switches for higher-risk agents.
"What skills do validators need now?"	Prompt and retrieval design, evaluation methods, red-teaming, plus the traditional ones: statistics, scepticism and clear writing. Pair validators with engineers early.
"How do smaller firms cope?"	Tier hard, reuse validated patterns, and push vendors for evidence collectively. You can't out-resource the big banks, so don't validate what doesn't matter.

Prep call with Minhaj

Go in with a clear ask so you get the questions you want before the NatWest voices claim them.

What to say on the call (about 2 minutes)

- [ ] Your lane: independent validation, financial crime and fraud models, AI validation policy, UK + EU-group perspective
- [ ] Ask to lead **Q3 (validation)** and **Q7 (third-party/foundation models)**
- [ ] Offer short builds on Q2, Q5 and Q8
- [ ] Agree the split with Soung on Q3 (what to test vs how to test) and with Chhavi on Q8 (model monitoring vs control automation)
- [ ] Check with Liam that your Lloyds-era examples don't cut across his
- [ ] Ask Minhaj whether he wants a closing one-liner from everyone on Q10

- [ ] Confirm the session time and whether there are slides (assume none)

Before the 21st

- [ ] Get any internal approval Handelsbanken requires for external speaking, and check whether a standard disclaimer is expected ("views are my own")
- [ ] Confirm your title for the programme
- [ ] Rehearse the 20-second intro and the Q3 and Q7 answers out loud, timed

Things to avoid saying

- Names of internal models, vendors, findings or committee discussions, or anything about the content of the AI validation policy before it is approved
- "We don't use GenAI" or "we're far behind": frame it as a deliberate, proportionate approach
- Promising regulatory outcomes or quoting rules you haven't checked (see the Omnibus caveat above)
- Criticising other banks' approaches; build on co-panellists with "and to add the validation view…"

Sources

- Letter from Sarah Breeden and Sam Woods to the Chancellor, 1 April 2026
- PRA holds MRM roundtable on AI (Nov 2025)
- TLT: BoE and PRA plans for safe AI innovation
- Bratby Law: AI Consortium June 2026 minutes
- FinTech Futures: FCA AI Live Testing second cohort
- Sidley: provisional agreement to delay EU AI Act obligations
- SCL: Council of the EU approves AI Omnibus reforms

Background on SS1/23, SS2/21, SM&CR, DORA and the EU AI Act's general-purpose model and AI literacy provisions is from general knowledge, not pages opened for this brief. Check exact wording before quoting it on stage.